

NIMBUSGUARD TECHNOLOGIES, INC.

---

# Information Security Policy

Enterprise Governance, Risk & Compliance Framework

|                        |                         |                 |                          |
|------------------------|-------------------------|-----------------|--------------------------|
| <b>Document ID:</b>    | NG-ISP-001              | <b>Version:</b> | 4.2                      |
| <b>Effective Date:</b> | January 15, 2026        | <b>Owner:</b>   | CISO – Dr. Elena Vasquez |
| <b>Classification:</b> | Internal – Confidential | <b>Status:</b>  | Approved                 |

---

## 1. Purpose and Scope

This Information Security Policy establishes the overarching security governance framework for NimbusGuard Technologies, Inc. ("NimbusGuard" or "the Company"). It applies to all employees, contractors, temporary staff, and third-party service providers who access NimbusGuard information systems, data, or facilities. The policy covers all information assets regardless of format, including electronic data, paper records, and intellectual property.

NimbusGuard provides cloud-based Identity and Access Management (IAM) solutions from its headquarters in Portland, Oregon, with data center operations in US-East (Virginia), US-West (Oregon), and EU-West (Frankfurt). The Company processes data for over 2,400 enterprise customers across financial services, healthcare, government, and technology sectors.

## 2. Information Security Governance

### 2.1 Organizational Structure

The Board of Directors maintains ultimate accountability for information security. The Chief Information Security Officer (CISO) reports directly to the CEO and provides quarterly security briefings to the Board's Audit and Risk Committee. The Security Governance Committee, chaired by the CISO, meets monthly and includes the CTO, VP of Engineering, VP of Operations, General Counsel, and the Data Protection Officer (DPO).

### 2.2 Roles and Responsibilities

| Role                          | Responsibility                                                           |
|-------------------------------|--------------------------------------------------------------------------|
| CISO (Dr. Elena Vasquez)      | Overall information security strategy, risk management, and compliance   |
| DPO (Marcus Chen)             | Data privacy compliance, GDPR/CCPA oversight, privacy impact assessments |
| VP Engineering (Priya Sharma) | Secure SDLC, application security, code review processes                 |
| VP Operations (James Wright)  | Infrastructure security, SOC operations, incident response               |
| Security Architects           | Security design reviews, threat modeling, control implementation         |
| All Employees                 | Adherence to security policies, reporting incidents, completing training |

## 3. Risk Management

NimbusGuard employs a risk-based approach to information security aligned with ISO 27005 and NIST SP 800-30. Enterprise risk assessments are conducted annually, with targeted assessments performed for all new systems, significant changes, and third-party integrations. Risks are evaluated using a 5x5 likelihood-impact matrix and tracked in the GRC platform (ServiceNow GRC). Risk treatment plans require CISO approval and are reviewed quarterly.

The Company maintains a formal risk appetite statement approved by the Board. Residual risks rated 'High' or 'Critical' require explicit Board acceptance. NimbusGuard's current risk register contains 147 identified risks, of which 12 are rated High and none Critical.

## 4. Compliance and Audit

NimbusGuard maintains the following certifications and attestations:

- SOC 2 Type II (annual, audited by Deloitte) – Trust Service Criteria: Security, Availability, Confidentiality, Processing Integrity
- ISO 27001:2022 certified (certification body: BSI Group, certificate #IS-789456)
- ISO 27017:2015 (Cloud Security Controls)
- ISO 27018:2019 (Protection of PII in Public Clouds)
- CSA STAR Level 2 Attestation
- FedRAMP Moderate Authorization (Agency: GSA, Authorization Date: March 2024)
- HIPAA Business Associate capabilities (BAA available upon request)
- PCI DSS v4.0 Level 1 Service Provider

Internal audits are conducted quarterly by the Internal Audit team, supplemented by annual external penetration tests (performed by CrowdStrike Services) and continuous automated compliance monitoring via Wiz Cloud Security Platform.

## 5. Policy Framework

This Information Security Policy is supported by the following subordinate policies, each of which is reviewed and updated at least annually:

- NG-DPP-002: Data Protection and Privacy Policy
- NG-BCP-003: Business Continuity and Disaster Recovery Plan
- NG-IRP-004: Security Incident Response Plan
- NG-HRS-005: Human Resources Security Policy
- NG-INF-006: Infrastructure and Operations Security Policy
- NG-IAM-007: Identity and Access Management Policy
- NG-VSM-008: Vendor and Supply Chain Management Policy

## 6. Policy Review and Approval

| Approver          | Title                  | Date         | Signature   |
|-------------------|------------------------|--------------|-------------|
| David Nakamura    | CEO                    | Jan 10, 2026 | D. Nakamura |
| Dr. Elena Vasquez | CISO                   | Jan 12, 2026 | E. Vasquez  |
| Rachel Torres     | General Counsel        | Jan 14, 2026 | R. Torres   |
| Michael Okonkwo   | Chair, Audit Committee | Jan 15, 2026 | M. Okonkwo  |